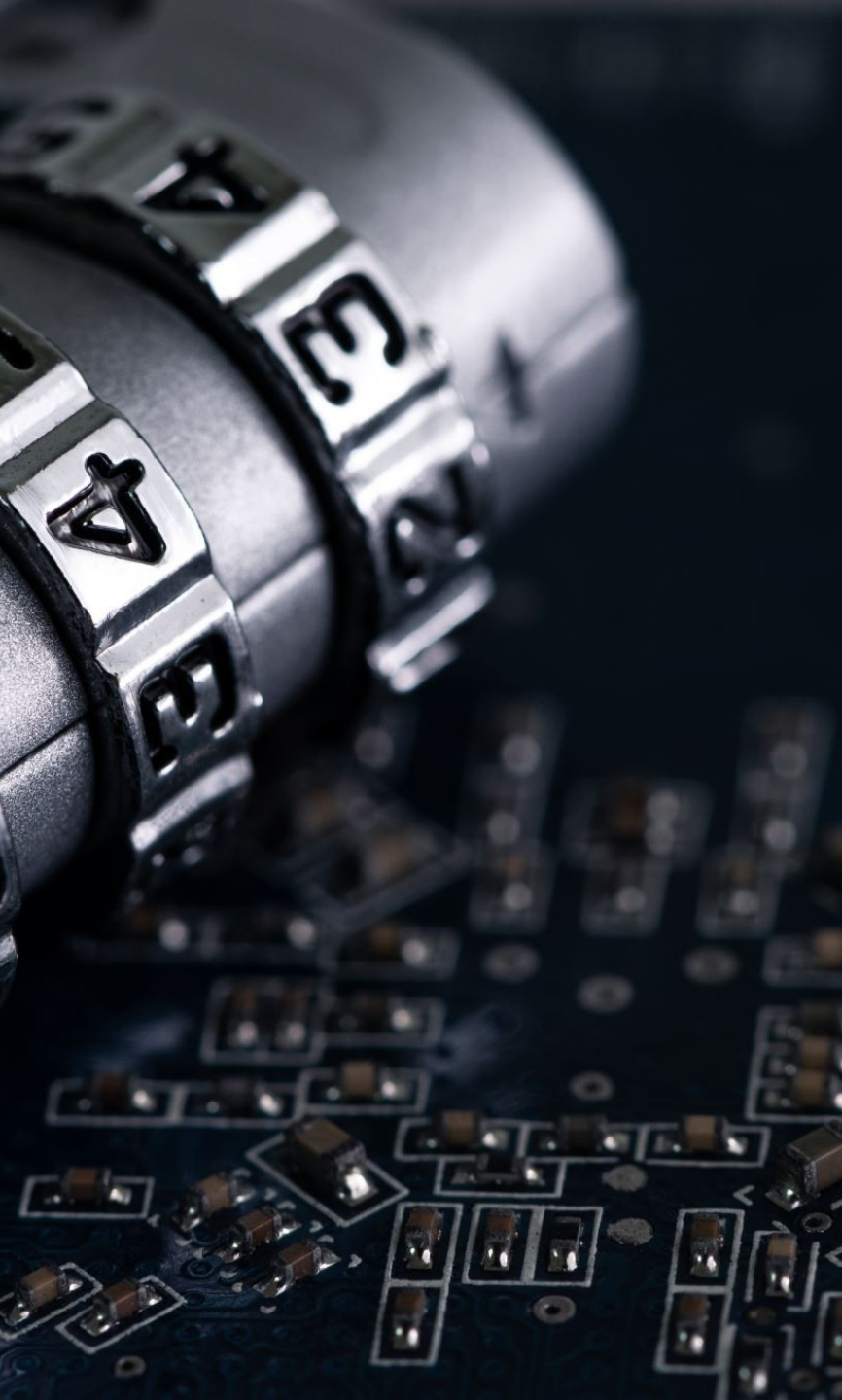




ICT Risk Management Framework (Articles 5–15)

KEY PROVISIONS AND IMPLEMENTATION GUIDELINES UNDER ARTICLES
5–15



GRC GATE TRAINING

The Role of ICT Risk Management Under DORA

ICT underpins organizational processes, communication, and service delivery

- Modern organizations rely on ICT as their digital foundation

Mismanaged ICT risk can cause disruption or regulatory sanctions

- Operational, reputational, and compliance impacts are possible

DORA establishes robust EU ICT risk regulations, Articles 5-15

- Organizations must adopt formal, adaptive, comprehensive risk management

DORA compels risk management program architecture

- Regulatory framework aims for resilience and accountability

Risk Policy: The Foundation of ICT Risk Management

Risk policy defines organizational approach to uncertainty

- It codifies values, priorities, and non-negotiables

Policies may mandate technical requirements, e.g., data encryption

- Requirements set boundaries for acceptable risk

Policy sets organizational tolerance for risk

- Example: encryption in transit and at rest is non-negotiable

Risk policy is formal, not just a technical preference

- It guides acceptable and unacceptable practices



Risk Tolerance: Guiding Decision-Making

Risk tolerance defines the organization's appetite for risk

- It is a nuanced set of parameters, not a single threshold

Tolerance varies by context, e.g., emergencies vs. routine

- Example: hospitals allow more open access during critical care

Calibration shapes daily decisions and resource allocation

- Investment in controls is informed by tolerance

Tolerance is a compass for investment and controls

- Not just theoretical; impacts day-to-day actions



Mapping Controls to Identified Risks

Controls translate policy and tolerance into actionable measures

- Controls include authentication, monitoring, and protective tools

Every key risk must have a mapped, proportional control

- Controls are effective and neither over- nor under-engineered

Over-engineered controls hinder innovation and workflow

- Under-engineered controls leave gaps and vulnerabilities

Control-mapping ensures resources address prioritized threats

- Controls should fit each specific threat context



Real-World Scenario: Insurance Company and Ransomware

ICT risk policy requires regular backups and escalation paths

- Policies mandate action for ransomware threats

Risk tolerance allows maximum 4-hour downtime for essential services

- Stricter limits for customer-facing platforms

Controls include backup validation, segmentation, red-teaming

- Automated and simulated measures bridge risk and resilience

Post-incident, policies and tolerance are reassessed for continued fit

- Review technical and threshold adequacy after incidents





Scenario: Logistics Firm and Cloud Fleet Management

Risk policy requires all system access logged and reviewed monthly

- Regular review ensures oversight of user activity

Risk tolerance allows one failed login per user per day

- Alerts trigger after threshold is exceeded

Controls include role-based access and anomaly detection

- Measures target credential compromise and misuse

Policy updates and tolerance adjustments follow emerging threats

- Phishing incidents prompt stricter, group-specific parameters

Principles for Compliant Framework Design

Framework requires alignment with organizational mission and context

- Avoid copying regulatory text or off-the-shelf controls

Treat risk policy as a living guide, not a static document

- Policy should be referenced in daily decisions

Engage stakeholders across the organization in creation and review

- Participation surfaces risks not found in technical assessments

Different functions highlight unique risk perspectives

- Customer service notes reputational risks; IT focuses on technical feasibility



Explicit, Adaptive Risk Tolerance

Risk tolerance must be transparent and aligned with real priorities

- Avoid arbitrary thresholds disconnected from business needs

Anchor tolerance in impact assessments and expectations

- Factor in regulatory and stakeholder requirements

Low tolerance for core services, higher for innovation when controlled

- Example: payments vs. research unit sandboxing

Controls must reflect the chosen level of tolerance

- Control environment must match risk appetite



Customizing and Validating Controls

Use standards as reference points, not rigid templates

- ISO 27005 and NIST SP 800-53 can inform design

Tailor controls to unique risk profile of your organization

- Avoid one-size-fits-all approaches or unnecessary layers

Regularly test controls via simulation, audit, and red-teaming

- Controls on paper may fail without real-world embedding

Balance practicality with necessity for different worker scenarios

- Example: token-based authentication for remote vs. executive users



Self-Assessment and Reflection

Assess policy visibility and understanding within the organization

- Determine if policies are referenced outside audits

Evaluate clarity of organizational risk tolerance in practice

- Decisions should reflect strategic priorities

Inspect control mapping for coverage and redundancy

- Precision prevents overlaps and dangerous gaps

Identify exposures through ongoing review and questioning

- Reflection connects theory and lived experience

Avoiding Compliance-Only Mindset

“Check-the-box” compliance can leave organizations vulnerable

- Passing audits does not equal true resilience

Foster culture of continuous improvement, not mere compliance

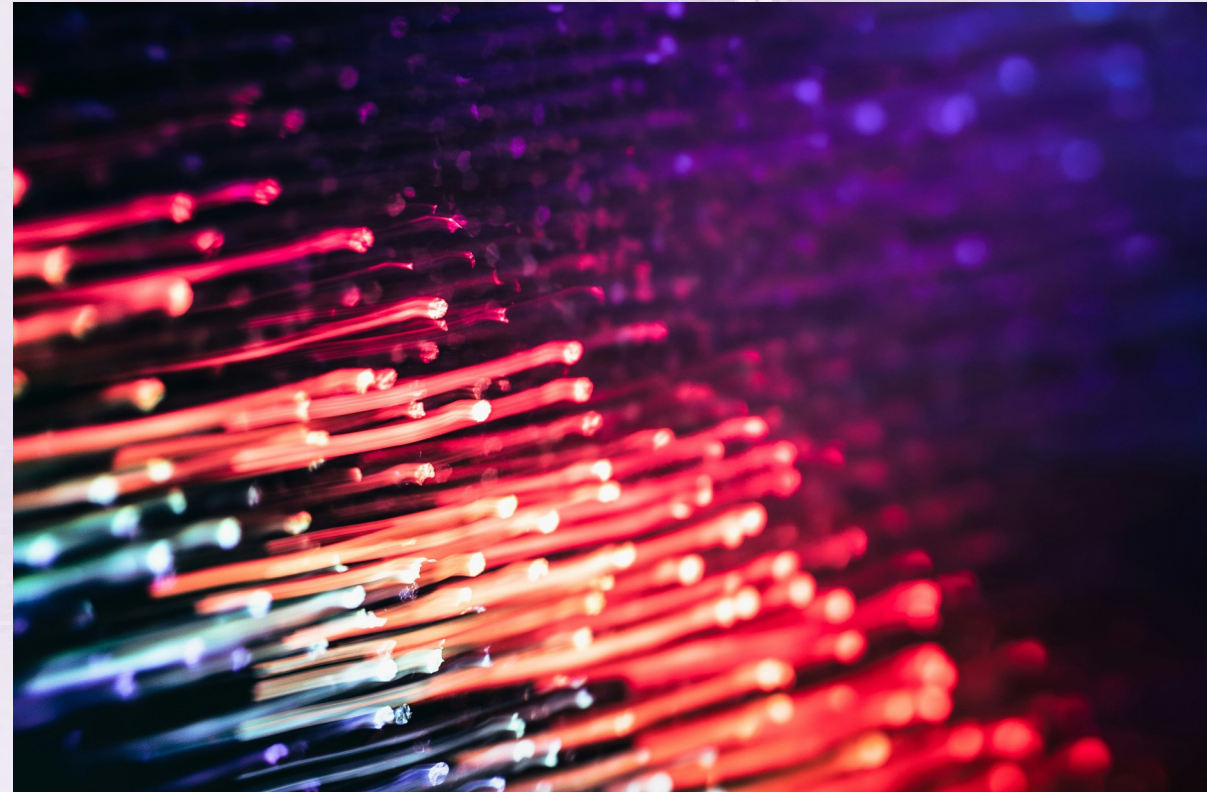
- Regularly review appetite, update policies, and test controls

Encourage near-miss reporting for systemic insights

- Minor incidents often reveal deeper issues

Use new threat intelligence to update risk framework

- Test against emerging threats, not only known risks



Overcoming Siloed Risk Management

Siloed IT, compliance, and business units cause misalignment

- Fragmentation leads to incomplete risk views and gaps

Promote cross-functional collaboration for major projects

- Involve IT, legal, HR, and frontline teams

Joint discussions reveal blind spots and alignment issues

- Broader inclusion results in robust risk outcomes

Unified application of risk, tolerance, controls increases resilience

- Consistency prevents misapplied or conflicting controls



Human Element in ICT Risk Management

Policies and controls require awareness and engagement of people

- Engagement drives the effectiveness of risk frameworks

Training and communication reinforce practices and expectations

- Leadership by example is essential for compliance culture

Leadership behaviors signal importance of compliance

- Executives bypassing controls undermines the framework

Champions set organizational tone for risk management

- Visible leadership cascades priorities throughout the workforce



Assessment and Continuous Improvement

Perform regular gap analyses versus regulatory standards and best practices

- Compare current state to DORA and industry benchmarks

Use metrics to identify enhancement opportunities, not just compliance

- Track reviews, testing, and incident detection rates

Adjust tolerance, retire obsolete controls based on insights

- Fine-tune framework with ongoing data

Metrics help reinforce organizational risk culture

- Improvement drives sustained resilience

Reflection: Linking Practice to Framework Strength

Examine past incidents or near misses for risk management lessons

- Outcomes reveal strengths or weak points in framework

Trace events to clarity of policy and control effectiveness

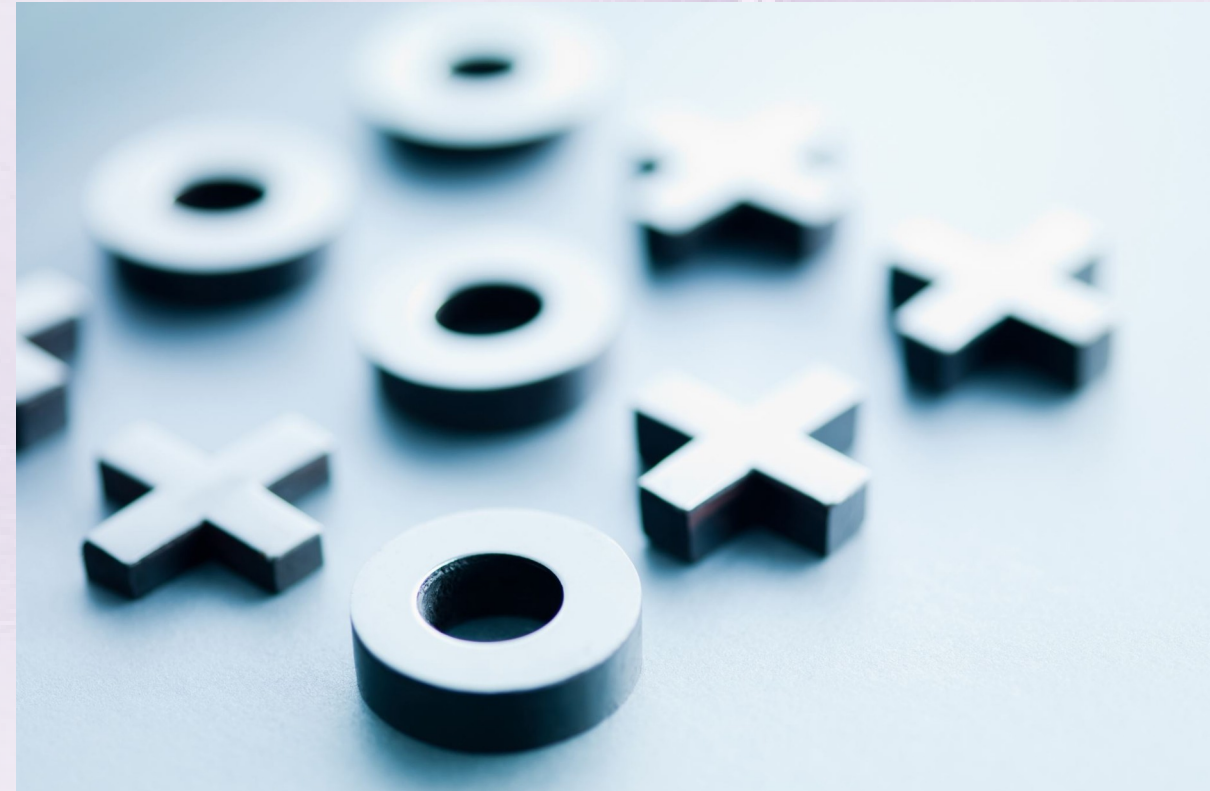
- Consider if mapping, policy, or tolerance failed or succeeded

Learn from experience to adapt risk framework over time

- Iterative reflection builds resilience and adaptability

Self-assessment grounds improvement in actual events

- Connects lived events with theoretical constructs



DORA Principles and Organizational Proportionality

DORA Articles 5-15 set principles, not one-size-fits-all models

- Frameworks must reflect proportionality, comprehensiveness, integration

Approaches should scale with organization size and complexity

- Small fintech startups adopt lean processes reviewed regularly

Global banks use layered structures and automation for criticality

- Specialized teams and complex protocols for larger institutions

Framework integrates with overall organizational governance

- Principles ensure fit with strategic objectives



Resilience Through Interplay of Elements

A compliant framework anticipates, withstands, and recovers from disruption

- Policies, tolerance, and controls form the toolkit for resilience

Ongoing dialogue and learning ensure robustness

- Human judgment and organizational reflection are essential

Framework is both shield and compass against threats

- Guides response to cyberattacks, supply failures, insider risks

Resilience emerges from interaction, not static documents

- Dialogue and adaptation cement operational security



Clarity, Alignment, and Adaptability in Framework Construction

Craft policies that are accessible, actionable, and regularly updated

- Policies must clearly reflect organizational risk stance

Define risk tolerance as living, needs-based, not static

- Tolerance changes with business and stakeholder requirements

Map controls and validate effectiveness by testing and feedback

- Precision and review are essential for coverage

Foster culture of collaboration, learning, and accountability

- People are core strength in framework effectiveness

Beyond Compliance: Fortifying Organizational Trust

Foundational work meets regulatory mandates and fortifies against the unknown

- Strengthens resilience for customers, partners, and regulators

Internalizing these principles positions you for organizational defense

- Responsible application aids organizational success

Your engagement transforms compliance into operational resilience

- Commitment to mastery drives improvement

Reflect, challenge, and elevate ICT risk management continuously

- Lifelong learning cements security culture

